Azure DevOps hardening after Key Eater: pipelines, identity

An expert Azure DevOps Services hardening playbook: Key Eater evidence limits, PAT controls, WIF, service-connection checks, job-token scope, agent isolation, KQL hunts and safe rollback.

8 phases | 24 steps | Tick each item when its "done when" criterion is true

Phase 1 Scope the trust chain and preserve evidence about Half a day

- [ ] **1.1 Separate the campaign evidence from the hardening decision**
  The incident ticket distinguishes Todyl observations, unknowns and our defensive recommendations
- [ ] **1.2 Inventory identities, connections and authorities without collecting secrets**
  The inventory records organization/project, connection ID, identity IDs, Azure scope, allowed pipelines, checks, owner and exception expiry
- [ ] **1.3 Export what exists before retention or cleanup removes the trail**
  Available audit exports and pipeline evidence are preserved with a time window and collection gaps

Phase 2 Constrain human sessions and PAT exceptions about Half a day

- [ ] **2.1 Target Azure DevOps itself in user Conditional Access**
  Report-only evidence covers the intended users and Azure DevOps resource, with emergency access validated
- [ ] **2.2 Validate non-interactive IP fencing separately**
  A sanctioned allowed-path and denied-path check has an owner and captured outcome
- [ ] **2.3 Restrict PAT creation, scope and lifespan; revoke compromised tokens explicitly**
  Each remaining token has an owner, narrow scope and expiry, and incident tokens are revoked

Phase 3 Replace secrets without leaving the trust issuer unguarded about Half a day

- [ ] **3.1 Build a narrow WIF pilot rather than a fleet-wide conversion**
  A nonproduction pipeline uses a dedicated WIF connection and an explicitly recorded Azure permission scope
- [ ] **3.2 Retire the old credential only after pilot evidence**
  The production task path has a successful sanctioned verification and the unused old credential has an approved removal decision
- [ ] **3.3 Reduce who can create, administer and consume deployment connections**
  Resource owners have reviewed connection Security and pipeline permissions with named backups

Phase 4 Put production gates on the resource, not only in YAML about Half a day

- [ ] **4.1 Protect the service connection with branch control**
  A new run from an unapproved branch cannot consume the production connection
- [ ] **4.2 Require independent approval and constrain override rights**
  Production consumption waits for a designated independent approver and bypass rights are reviewed
- [ ] **4.3 Prove both a permitted and a denied consumption path**
  Run IDs show an approved run waiting/passing and a disallowed branch or unauthorized pipeline blocked

Phase 5 Reduce job-token and repository blast radius about Half a day

- [ ] **5.1 Enable project-scoped job authorization in a pilot**
  The pilot succeeds with the project build identity and documented cross-project exceptions only
- [ ] **5.2 Protect repository access and repair narrow dependencies**
  Only explicitly referenced and authorized Azure Repos repositories are used by the YAML job
- [ ] **5.3 Keep fork validation away from deployment trust**
  External PR validation has no production connection, secrets or privileged self-hosted pool

Phase 6 Contain agents and secondary credential exposure about Half a day

- [ ] **6.1 Separate trusted deployment agents from untrusted builds**
  Production pool permissions, runtime account and network paths are documented

- [ ] **6.2 Keep remaining secrets out of YAML and incident artifacts**
  The pilot uses no embedded credential; unavoidable secrets have restricted access and rotation ownership

Phase 7 Hunt across Entra and Azure DevOps without inventing telemetry about Half a day

- [ ] **7.1 Search service-principal sign-ins including failures**
  Results are reviewed for app identity, credential type, resource and outcome; missing ingestion is recorded
- [ ] **7.2 Correlate DevOps changes and executions separately**
  Audit hits retain actor, organization, operation, IP and correlation ID for incident review
- [ ] **7.3 Widen to behavior and validate before alerting**
  A baselined candidate detection has exclusions, an owner and a documented false-positive review

Phase 8 Contain an incident, recover safely and hand over about Half a day

- [ ] **8.1 If evidence is suspicious, contain the whole credential chain**
  An incident lead owns app, session, DevOps and downstream credential containment with preserved evidence
- [ ] **8.2 Apply workload Conditional Access only within its supported scope**
  Policy coverage and unsupported identities are written down before anyone calls the tenant protected
- [ ] **8.3 Troubleshoot narrowly and define safe rollback**
  Every failing dependency has a targeted repair or time-bound exception, not a blanket permission reset
- [ ] **8.4 Accept the hardening only with evidence and operational ownership**
  Approved and denied paths, identity permissions, log coverage and rollback are signed off

Owner	Change / ticket	Date completed

Original checklist by Tenant Recipes, an independent project not affiliated with Microsoft or any vendor. Every step, its actions, pitfalls and the official sources it was checked against are on https://tenantrecipes.com/guides/azure-devops-hardening-key-eater.html. Time estimates are our own planning figures. Confirm against the linked sources and test in a pilot before production.